WRITE UP WEEKLY CTF PRACTICE 02



NAMA: PUTU SATRIA NARAYANA WIDIARTHA

NIM: 260530911105

DIVISI: CYBER SECURITY

DAFTAR ISI

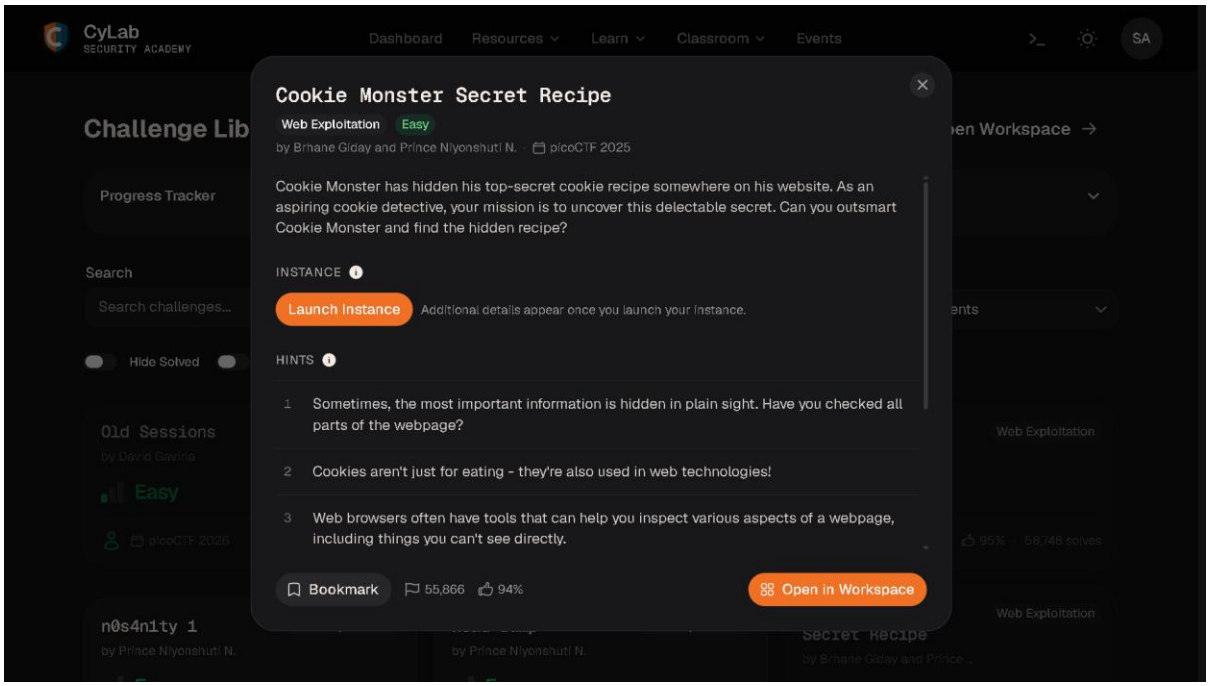
KATEGORI UTAMA: WEB 3
COOKIE MONSTER SECRET RECIPE 3
UNMINIFY 5
HEAD-DUMP 7
LOCAL AUTHORITY 9
N0S4N1TY 1 11
BOOKMARKLET 14
INSP3CT0R 16
KATEGORI FORENSICS 19
RIDDLE REGISTRY 19
BINARY DIGITS 21

KATEGORI UTAMA: WEB

COOKIE MONSTER SECRET RECIPE

Mengambil nilai HTTP cookie yang tersimpan, lalu melakukan proses decoding format URL dan Base64 untuk menemukan kode flag yang tersembunyi.

Link: https://learn.cylabacademy.org/library/469



Cookie Monster's Secret Recipe



Buka terlebih dahulu halaman challenge dan cobalah login dengan username serta password bebas.

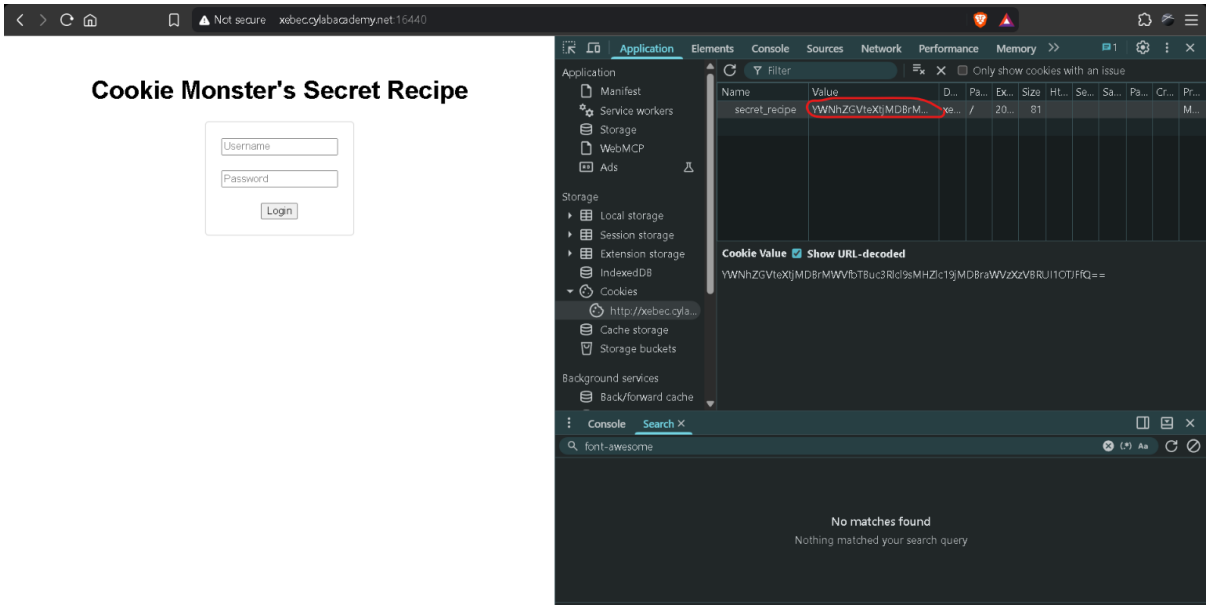
Access Denied

Cookie Monster says: 'Me no need password. Me just need cookies!'

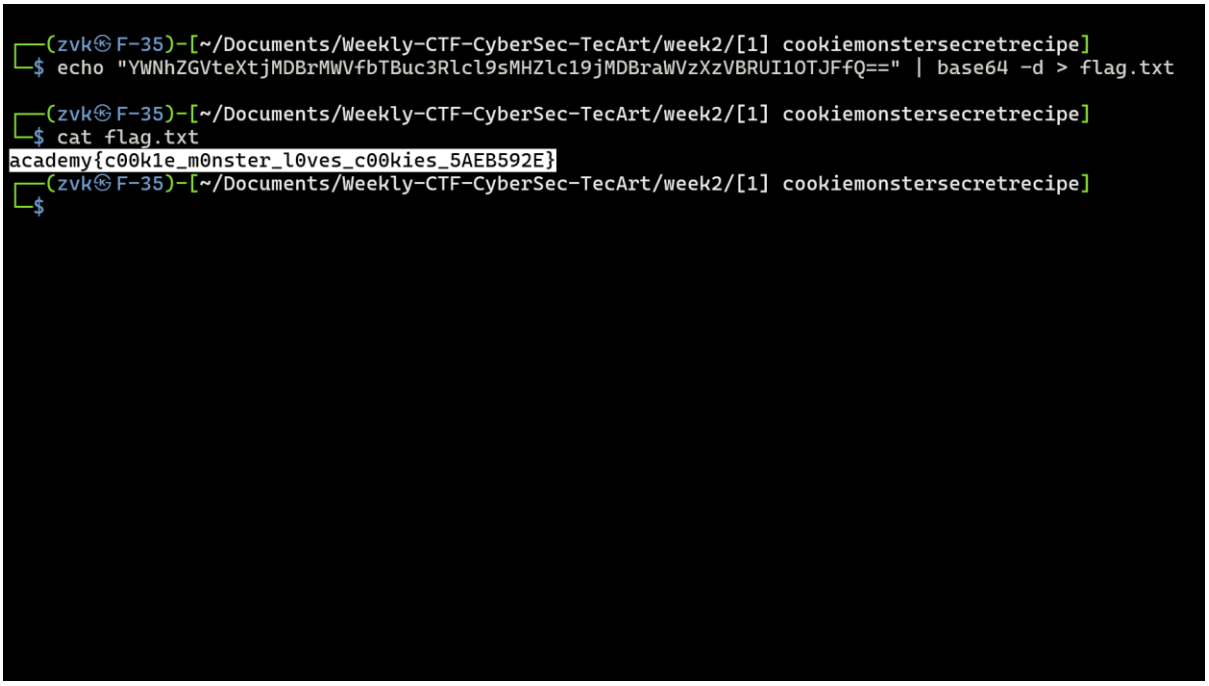
Hint: Have you checked your cookies lately?

Go back

Lalu pesan ini muncul “Access Denied – Cookie Monster says: 'Me no need password. Me just need cookies!'” muncul juga hint untuk memeriksa cookies yang tersimpan.



Saya membuka developer tools untuk mengecek. Disini ternyata ditemukan sebuah cookie bernama “secret_recipe” yang berisi string panjang menyerupai hasil encoding Base64.



Setelah value cookie tersebut disalin, decode aja pake perintah berikut:

```
echo "[value_cookie]" | base64 -d > flag.txt
```

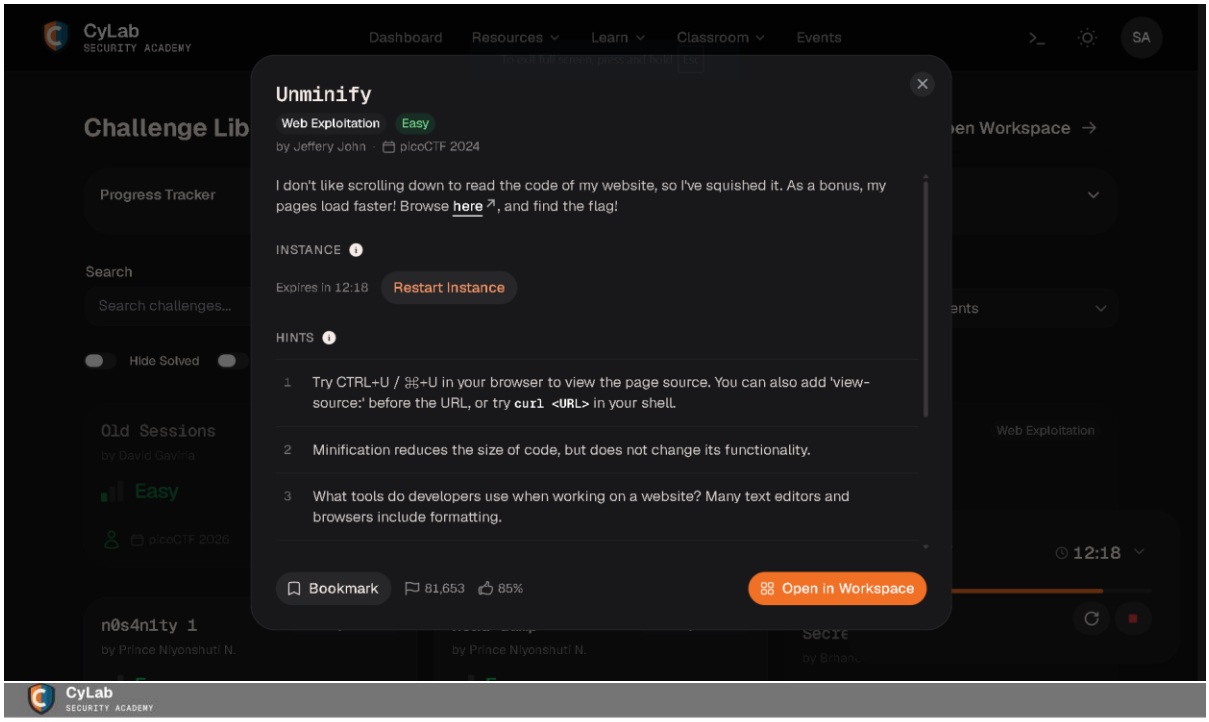
Setelah file flag.txt dibuka dengan cat, isinya berupa flag yang valid. Flag pun berhasil didapatkan.

Flag: academy{c00k1e_m0nster_l0ves_c00kies_5AEB592E}

UNMINIFY

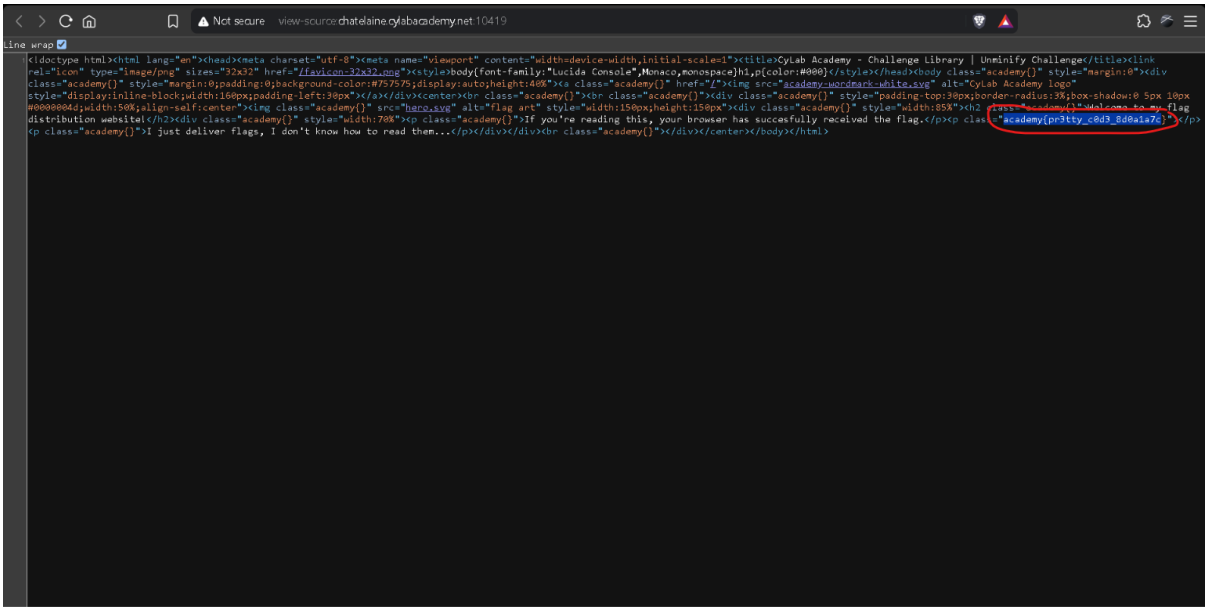
Kode sumber halaman web ini sengaja dikompresi menjadi satu baris (minified), sehingga user harus menggunakan fitur Inspect Element atau View Page Source pada browser untuk membaca struktur kode dan menemukan flagnya.

Link: https://learn.cylabacademy.org/library/527





Web pada challenge ini menampilkan halaman “Welcome to my flag distribution website!” yang menyatakan flag sudah “diterima” oleh browser, tapi kode sumbernya sengaja diminifikasi menjadi satu baris panjang sehingga sulit dibaca langsung lewat tampilan biasa.



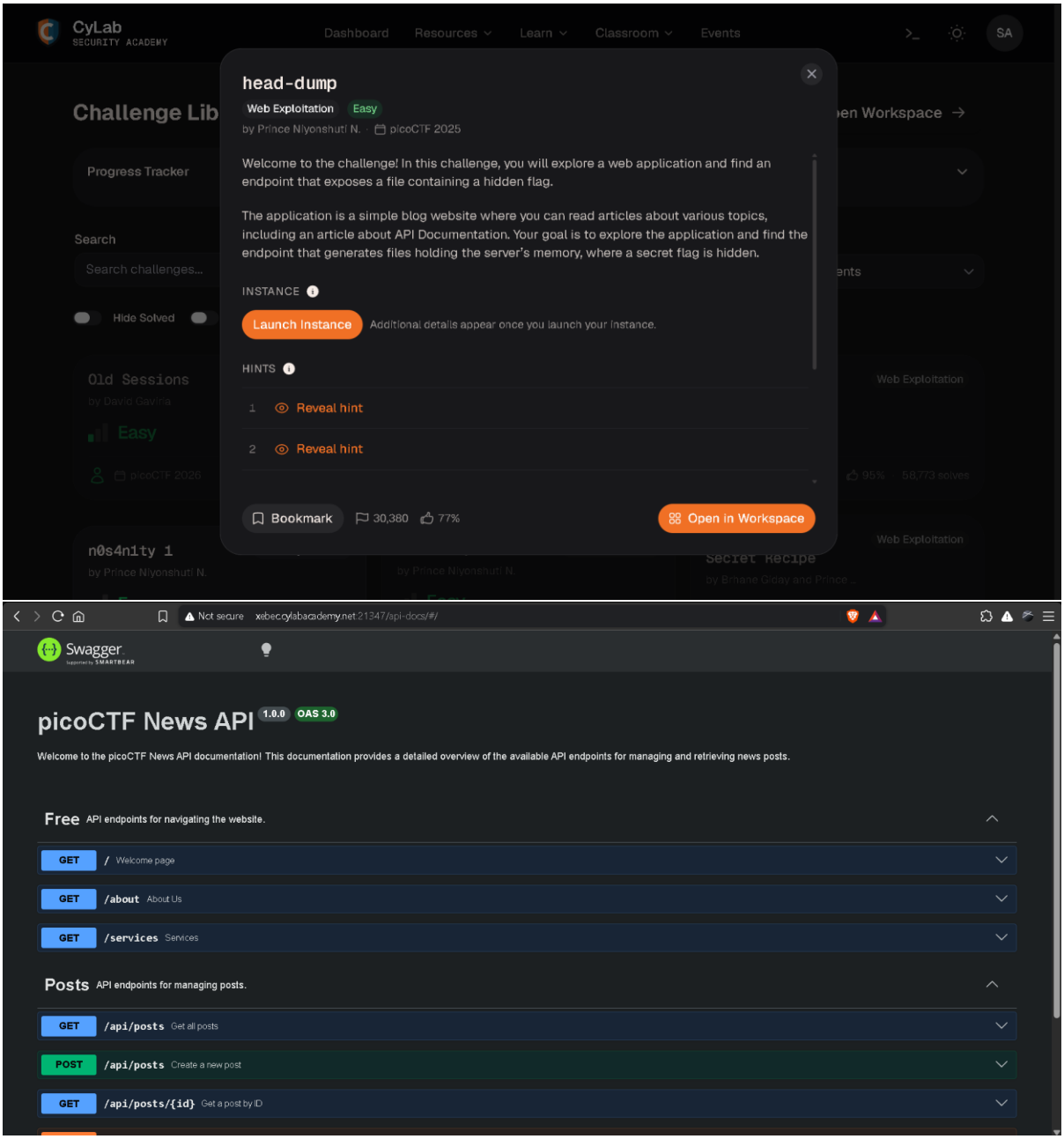
Sesuai hinnya, saya menambahkan “view-source:” di depan URL untuk melihat HTML mentahnya. Di dalam kode tersebut, flag ternyata tersembunyi langsung sebagai value dari salah satu atribut class pada elemen <p>, yaitu class=“academy{pr3tty_c0d3_8d0a1a7c}”. Flag pun berhasil didapatkan.

Flag: academy{pr3tty_c0d3_8d0a1a7c}

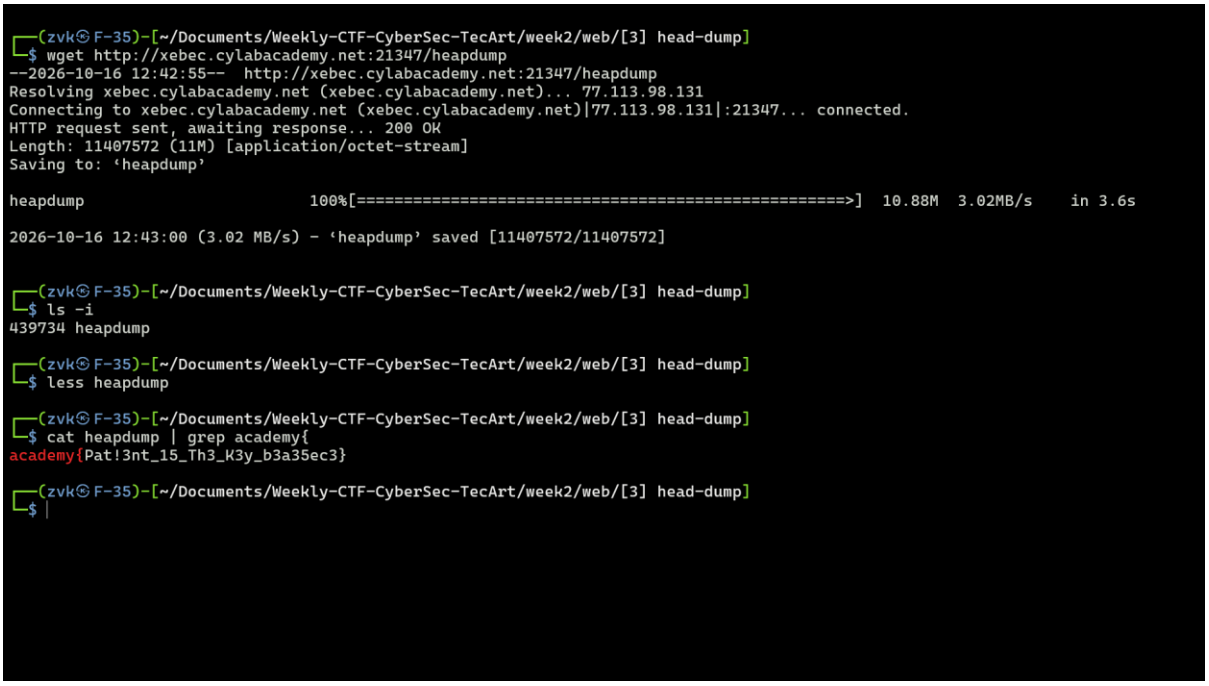
HEAD-DUMP

Mensimulasikan skenario di mana kesalahan konfigurasi pada API (Application Programming Interface) atau alat pembersihan kesalahan (debugging tools) dapat membocorkan informasi sensitif server kepada public.

Link: https://learn.cylabacademy.org/library/476



Saat membuka web soalnya, muncul tampilan blog sederhana. Saat diperiksa, ternyata ada url yang mengarah ke /api-docs/ lalu saya menemukan dokumentasi berjudul “picoCTF News API” yang mendaftar berbagai endpoint, seperti /api/posts untuk mengelola postingan hingga heapdump.



Karena nama challenge-nya adalah “head-dump”, yang merujuk pada heap dump/memory dump sebuah aplikasi, saya mencoba cocoklogi kemungkinan adanya endpoint debug tersembunyi, yaitu /heapdump, pada server yang sama. Ternyata endpoint tersebut bisa diakses. Unduh file tersebut menggunakan wget, lalu karena ukurannya cukup besar (sekitar 11 MB), jadi gunakan grep untuk mendapatkan flagnya:

```
cat heapdump | grep academy{
```

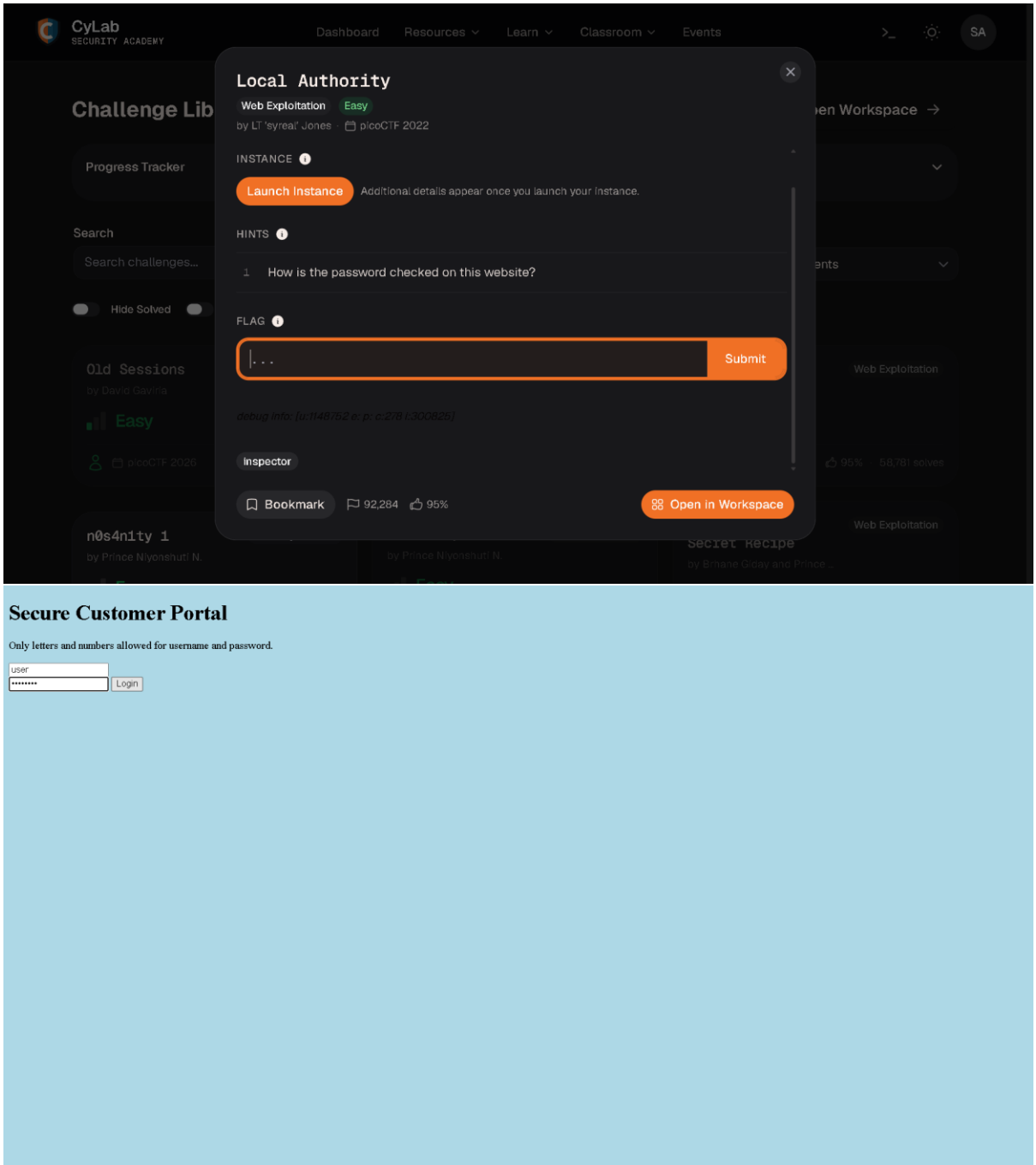
Flag pun berhasil ditemukan.

Flag: academy{Pat!3nt_15_Th3_K3y_b3a35ec3}

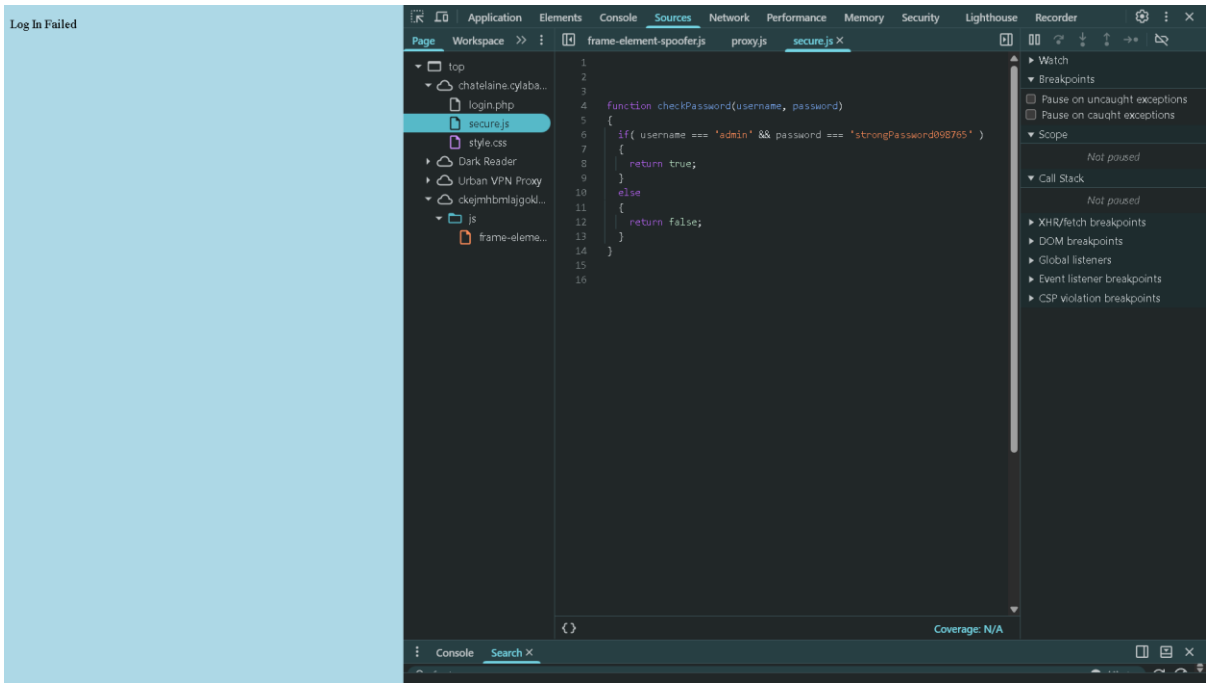
LOCAL AUTHORITY

Mengajarkan risiko keamanan akibat proses autentikasi yang ditaruh di sisi pengguna (client-side authentication).

Link: https://learn.cylabacademy.org/library/278



Di website soal, muncul halaman login dengan username dan password yang hanya boleh berisi huruf dan angka. Saat saya mencoba login input yang sembarang, muncul pesan “Log In Failed”.



Saya membuka developer tools pada tab sources dan menemukan file javascript bernama secure.js yang ternyata memuat seluruh logika validasi login di sisi client, termasuk username dan password, yaitu pengecekan username === 'admin' && password === 'strongPassword098765'.



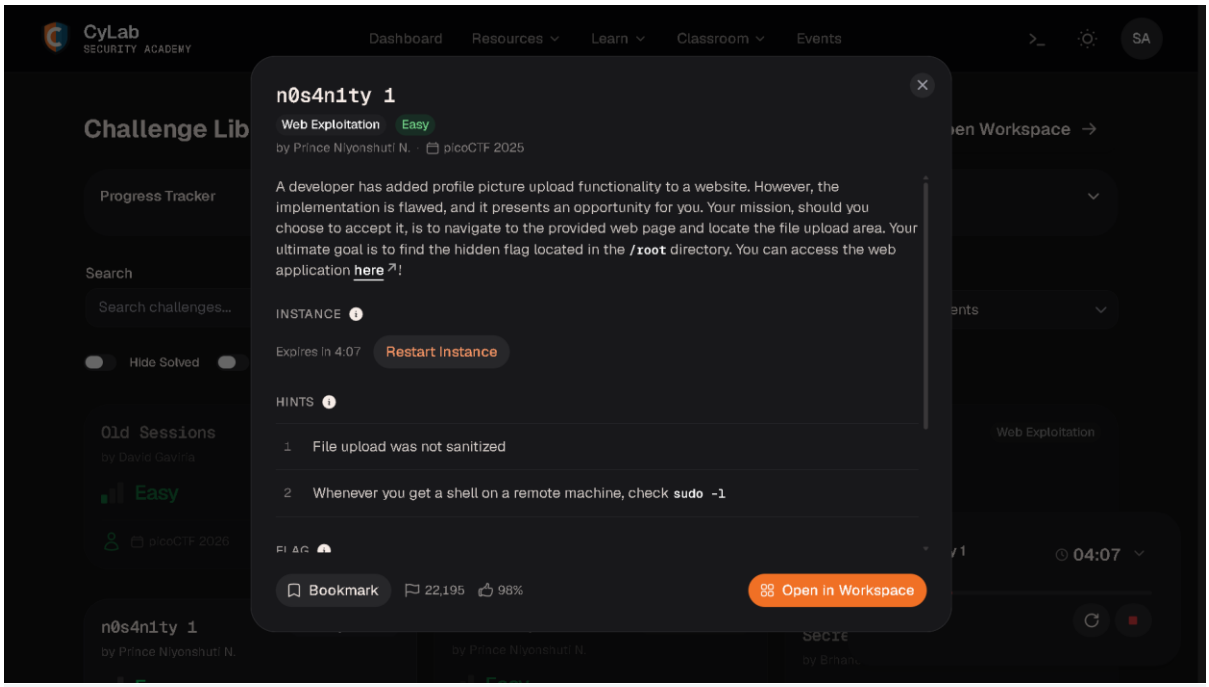
Saya login kembali menggunakan username admin dan password strongPassword098765 lalu berhasil masuk sehingga flag pun berhasil didapatkan.

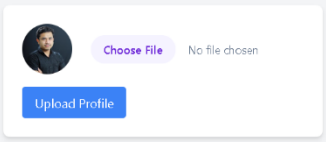
Flag: academy{j5_15_7r4n5p4r3n7_4fcce45f}

N0S4N1TY 1

Situs web target menyediakan fitur unggah berkas, namun sistemnya gagal melakukan sanitasi (input sanitization) atau validasi terhadap ekstensi dan isi berkas yang dikirimkan oleh pengguna.

Link: https://learn.cylabacademy.org/library/482

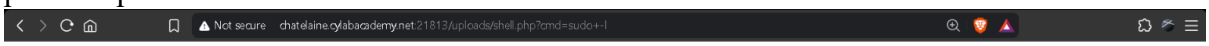




Website untuk soal ini berisikan fitur upload foto profil.

The file imagesmeme.jpg has been uploaded Path: uploads/imagesmeme.jpg

Saya mencoba mengupload file gambar biasa terlebih dahulu untuk melihat bagaimana respons server, dan ternyata server mengembalikan path lengkap tempat file disimpan, yaitu “The file imagesmeme.jpg has been uploaded Path: uploads/imagesmeme.jpg”. Karena path upload sudah diketahui dan server tidak melakukan validasi ekstensi file (sesuai hint pertama pada soal), saya mengupload sebuah file webshell berekstensi .php bernama shell.php, lalu mengaksesnya langsung melalui /uploads/shell.php?cmd=[perintah] untuk menjalankan perintah pada server.



Matching Defaults entries for www-data on challenge: env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty User www-data may run the following commands on challenge: (ALL) NOPASSWD: ALL

Mengikuti hint kedua, saya menjalankan perintah sudo -l melalui parameter cmd pada webshell tersebut:

```
/uploads/shell.php?cmd=sudo -l
```

Hasilnya menunjukkan bahwa user www-data diizinkan menjalankan “(ALL) NOPASSWD: ALL”, yang berarti saya bisa menjalankan perintah apapun dengan hak akses root tanpa perlu password.



flag.txt



academy{wh47_c4n_u_d0_wPHP_a93bcbae}

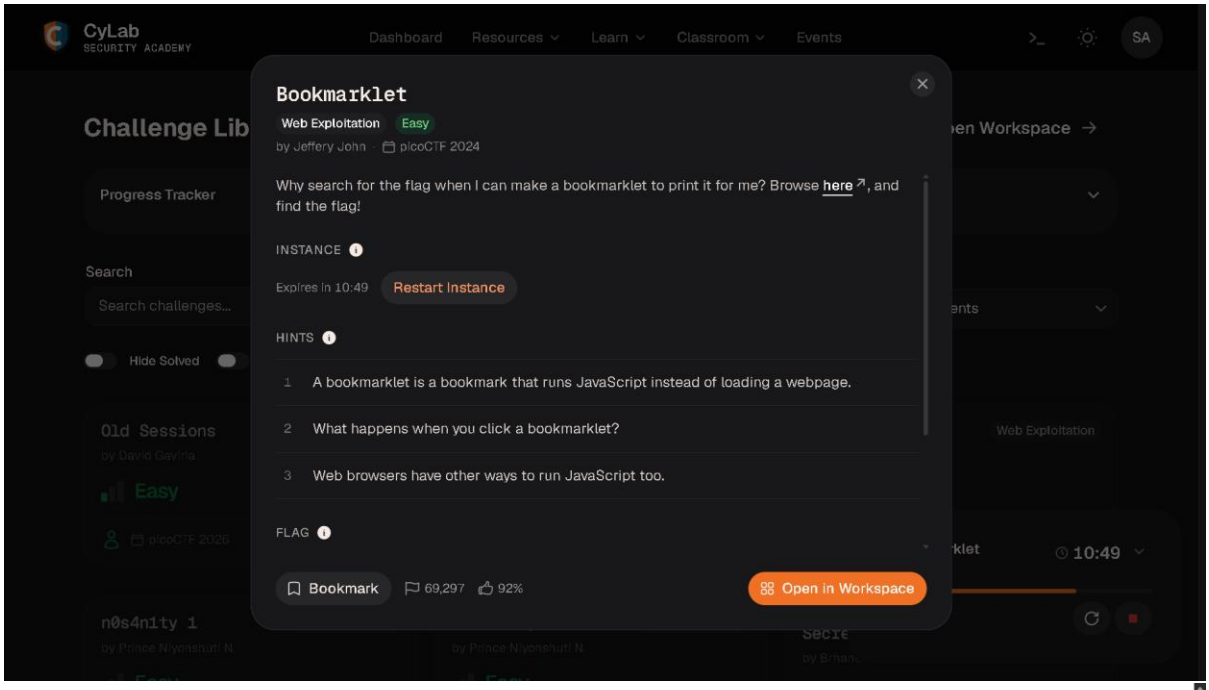
Saya kemudian menjalankan sudo ls /root melalui webshell yang sama untuk melihat isi direktori root dan menemukan file flag.txt, lalu membacanya langsung menggunakan sudo cat /root/flag.txt, dan flag pun berhasil didapatkan.

Flag: academy{wh47_c4n_u_d0_wPHP_a93bcbae}

BOOKMARKLET

Mengajarkan tentang konsep enkripsi sisi klien (client-side decryption) dan cara memanfaatkan fitur Browser Developer Tools Console.

Link: https://learn.cylabacademy.org/library/406





Welcome to my flag distribution website!

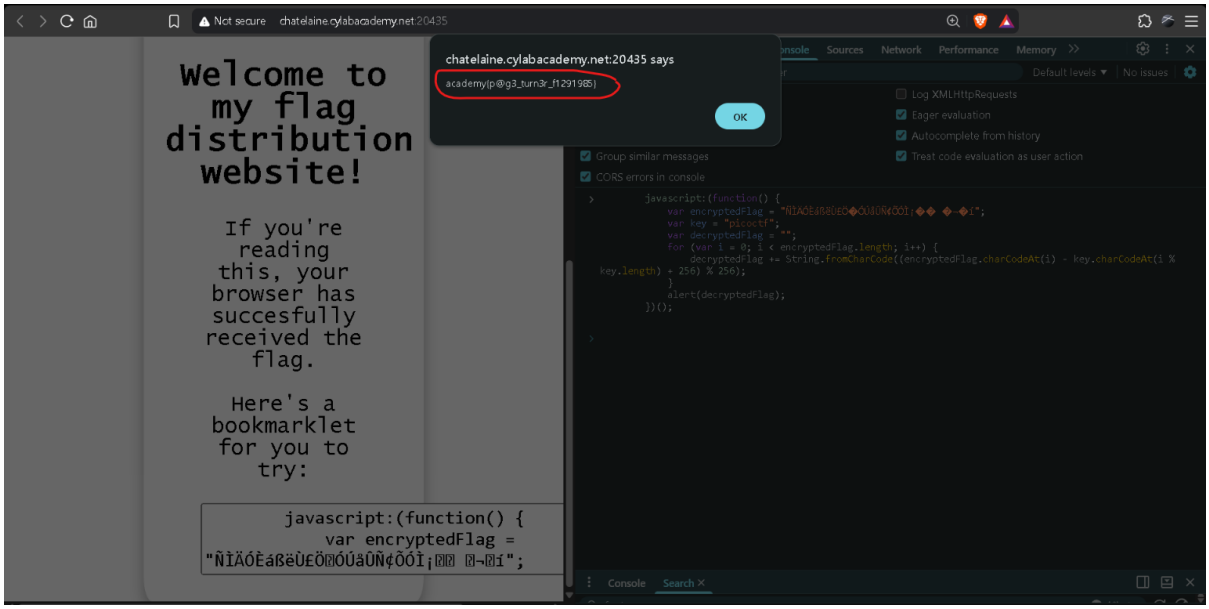
If you're reading this, your browser has succesfully received the flag.

Here's a bookmarklet for you to try:

```
javascript:(function() {
    var encryptedFlag =
"ÑÌÃÓÈáßëÙ£ÖØÓÚåÛÑ¢ÔÓÎ¡ØØ Ø¬ØíÑ";
```

Code copied to clipboard!

Website soal kali ini menampilkan pesan serupa dengan challenge Unminify di atas, yaitu “Welcome to my flag distribution website!”, namun kali ini disertai sebuah kode bookmarklet yang bisa disalin ke clipboard, berisi variabel encryptedFlag yang sudah terenkripsi.



Sesuai hint pada soal, saya menempelkan kode tersebut ke tab console pada developer tools browser agar bisa dieksekusi sebagai javascript biasa.

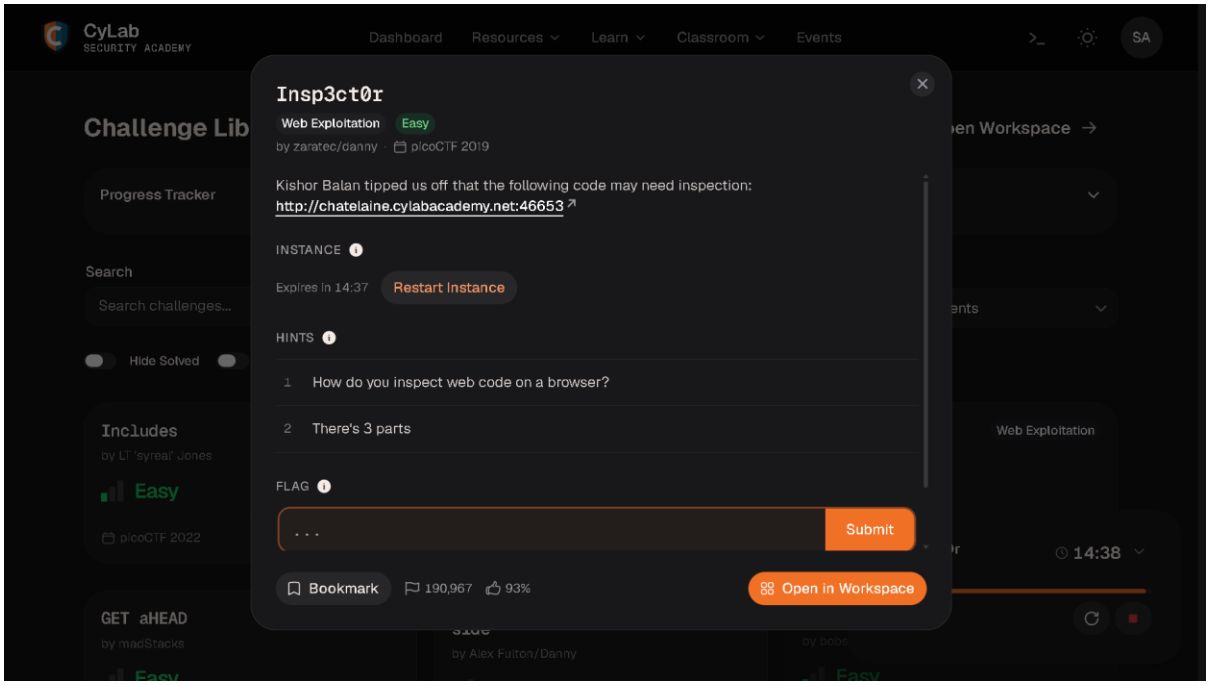
Dari kode yang tampil di console, terlihat bahwa flag dienkripsi menggunakan operasi XOR sederhana. Setelah kode dijalankan, muncul sebuah alert box pada browser yang langsung menampilkan hasil dekripsinya berupa flag yang kita cari.

Flag: academy{p@g3_turn3r_f1291985}

INSP3CT0R

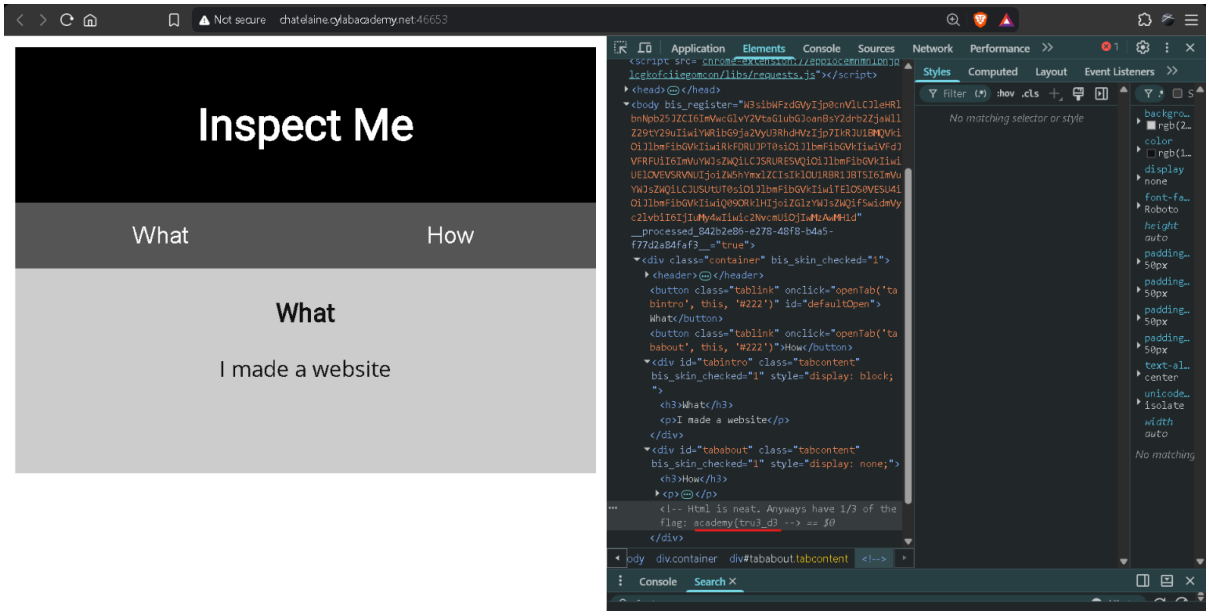
Menemukan potongan-potongan kunci rahasia (flag) yang disembunyikan oleh pengembang di dalam struktur halaman web.

Link: https://learn.cylabacademy.org/library/18

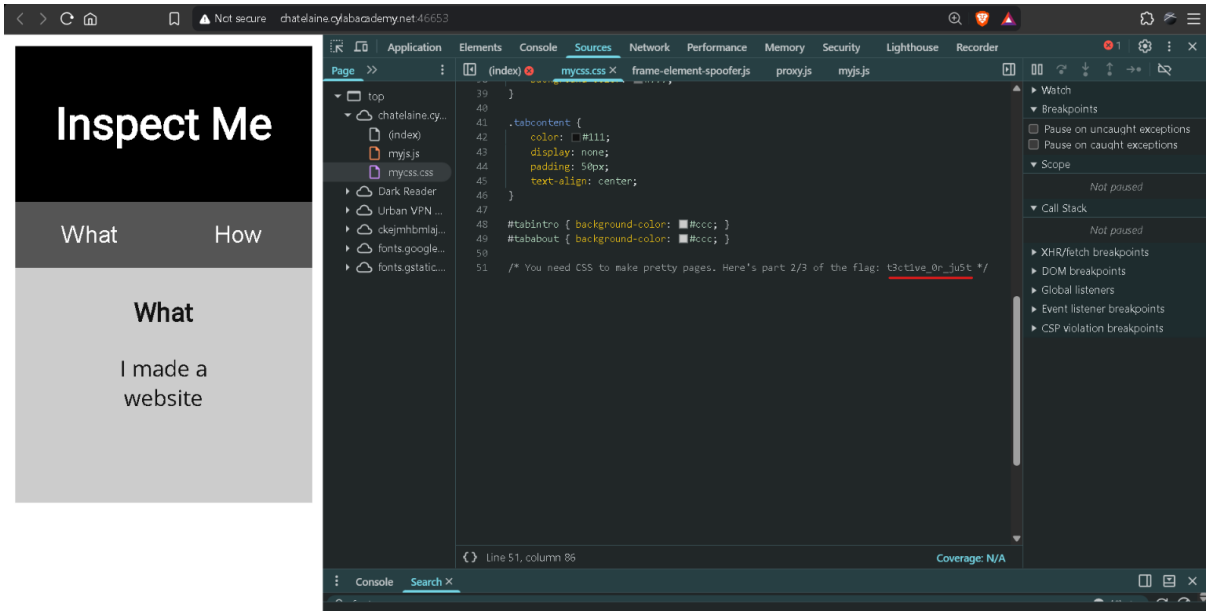




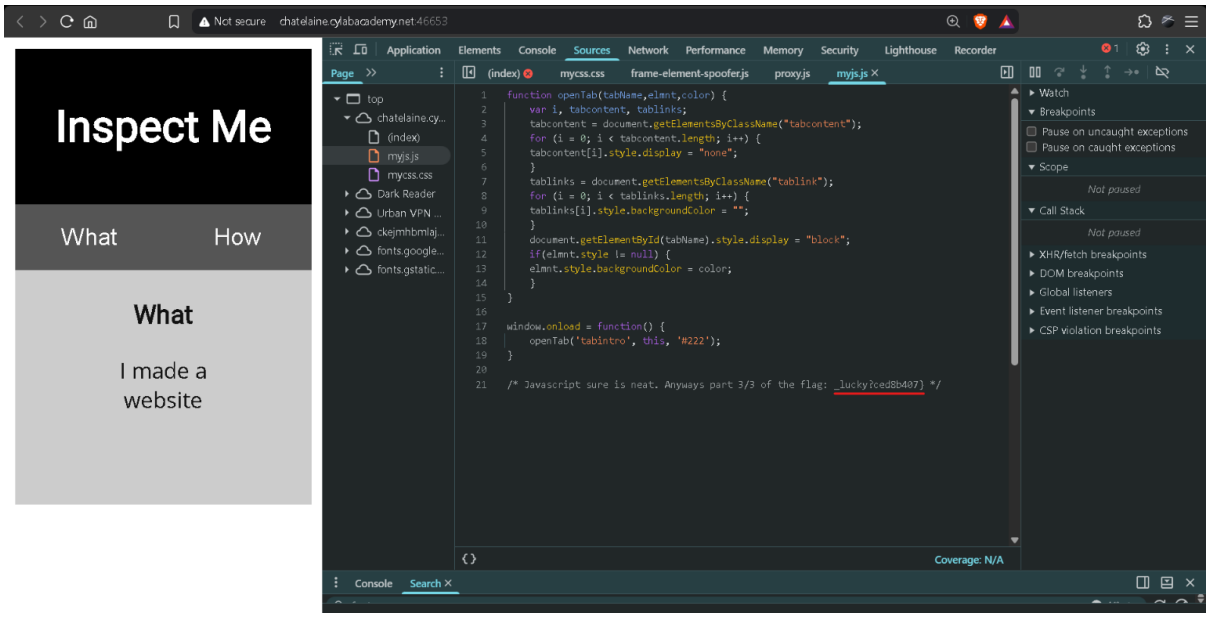
Deskripsi soal ini memberi hint bahwa flag pada challenge ini terbagi menjadi 3 bagian di dalam halaman “Inspect Me” yang diberikan. Jadi saya langsung mengeceknya dengan developer tools untuk menelusuri struktur HTML halaman ini.



Di bagian bawah tag body, ditemukan sebuah HTML comment yang menyimpan bagian pertama dari flag: “Html is neat. Anyways have 1/3 of the flag: academy{tru3_d3”.



Saya kemudian membuka tab sources dan memeriksa file mycss.css yang digunakan halaman ini. Di baris paling akhir file CSS itu, terdapat comment yang menyimpan bagian kedua dari flag: “t3ct1ve_0r_ju5t”.



Terakhir, saya memeriksa file myjs.js pada tab sources yang sama, dan menemukan comment di baris paling akhir berisi bagian ketiga sekaligus penutup flag: "_lucky?ced8b407}". Setelah ketiga bagian flag dari HTML, CSS, dan JavaScript ini digabungkan secara berurutan, flag pun berhasil didapatkan :).

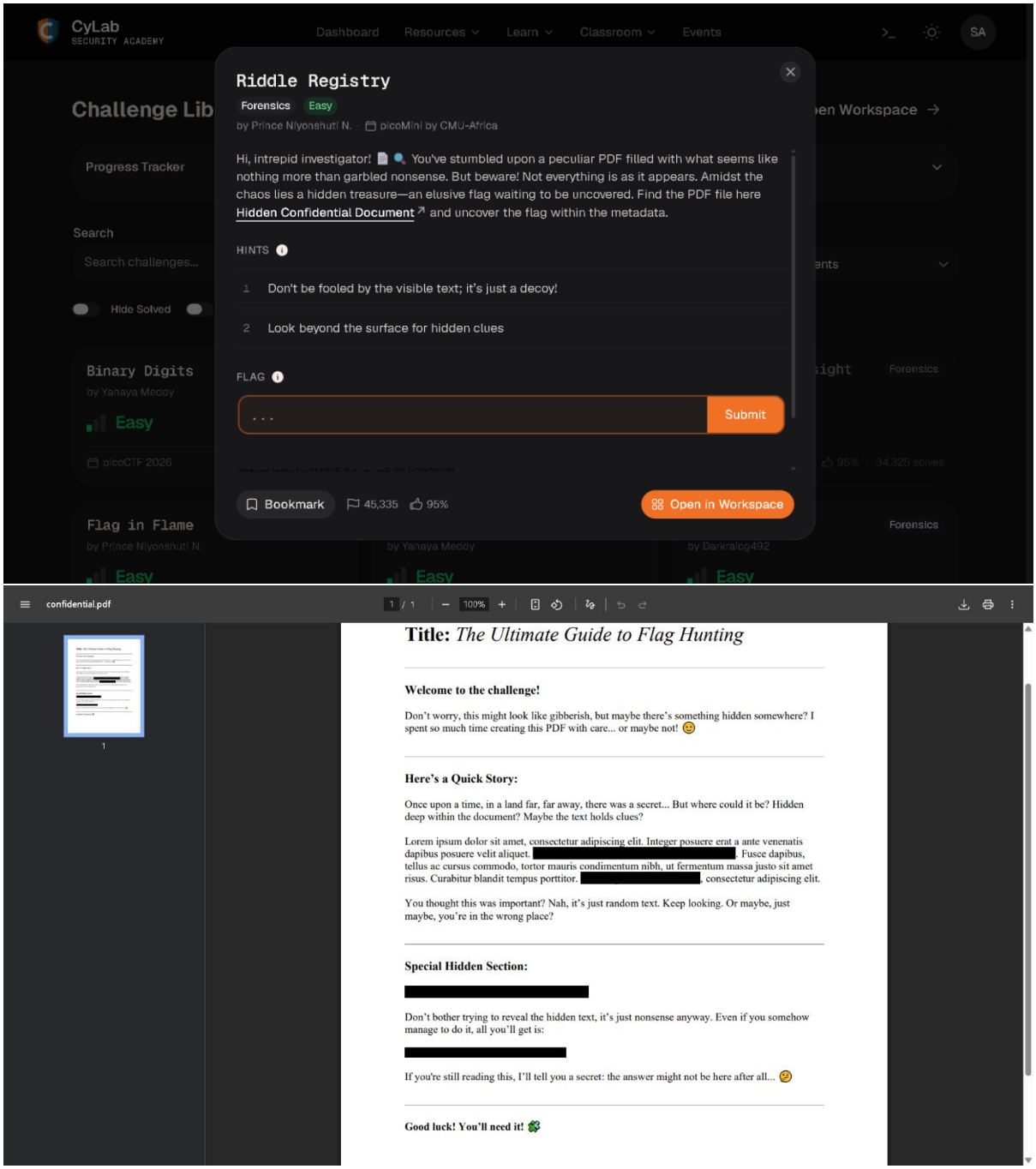
Flag: academy{tru3_d3t3ct1ve_0r_ju5t_lucky?ced8b407}

KATEGORI FORENSICS

RIDDLE REGISTRY

Berperan sebagai investigator yang mendapatkan sebuah file dokumen rahasia berformat PDF bernama confidential.pdf.

Link: https://learn.cylabacademy.org/library/530



Install file confidential.pdf yang diberikan menggunakan wget. Saat dibuka, dokumen PDF ini hanya berisi teks lorem ipsum dengan beberapa bagian yang sengaja dihitamkan sebagai jebakan, persis seperti yang disebutkan pada hint pertama bahwa teks yang terlihat hanyalah decoy.

```
┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[1] riddleregistry]
└─$ wget https://challenge-files.cylabacademy.net/library/f1a59c8fe4c030bdcdce963b06148196c62afa61f1e959134cd5b547347fddaf/confidential.pdf
--2026-10-16 18:24:47--  https://challenge-files.cylabacademy.net/library/f1a59c8fe4c030bdcdce963b06148196c62afa61f1e959134cd5b547347fddaf/confi
dential.pdf
Resolving challenge-files.cylabacademy.net (challenge-files.cylabacademy.net)... 13.35.1.94, 13.35.1.5, 13.35.1.79, ...
Connecting to challenge-files.cylabacademy.net (challenge-files.cylabacademy.net)|13.35.1.94|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 182532 (178K) [application/octet-stream]
Saving to: 'confidential.pdf'

confidential.pdf               100%[================================================>] 178.25K   913KB/s    in 0.2s

2026-10-16 18:24:47 (913 KB/s) - 'confidential.pdf' saved [182532/182532]


┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[1] riddleregistry]
└─$ file confidential.pdf
confidential.pdf: PDF document, version 1.7, 1 page(s)

┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[1] riddleregistry]
└─$ exiftool confidential.pdf
ExifTool Version Number         : 13.55
File Name                       : confidential.pdf
Directory                       : .
File Size                       : 183 kB
File Modification Date/Time     : 2026:09:23 14:28:06+08:00
File Access Date/Time           : 2026:10:16 18:24:51+08:00
File Inode Change Date/Time     : 2026:10:16 18:24:47+08:00
File Permissions                : -rw-r--r--
File Type                       : PDF
File Type Extension             : pdf
MIME Type                       : application/pdf
PDF Version                     : 1.7
Linearized                      : No
Page Count                      : 1
Producer                        : PyPDF2
Author                          : YWNhZGVteXtwdXp6bDNkX20zdGFkYXRhX2YwdW5kIV8zY2M3Y2VhOX0=

┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[1] riddleregistry]
└─$ echo "YWNhZGVteXtwdXp6bDNkX20zdGFkYXRhX2YwdW5kIV8zY2M3Y2VhOX0=" | base64 -d
academy{puzzl3d_m3tadata_f0und!_3cc7cea9}
```

Mengikuti hint kedua untuk mencari petunjuk “di luar” isi dokumen, saya mencoba memeriksa metadata file PDF tersebut menggunakan exiftool.
Pada hasil output exiftool, bagian “Author” ternyata tidak berisi nama penulis seperti biasanya, melainkan sebuah string Base64 yang agak sus. Setelah didecode dgn base64 menggunakan perintah berikut:

```
echo "[author_metadata]" | base64 -d
```

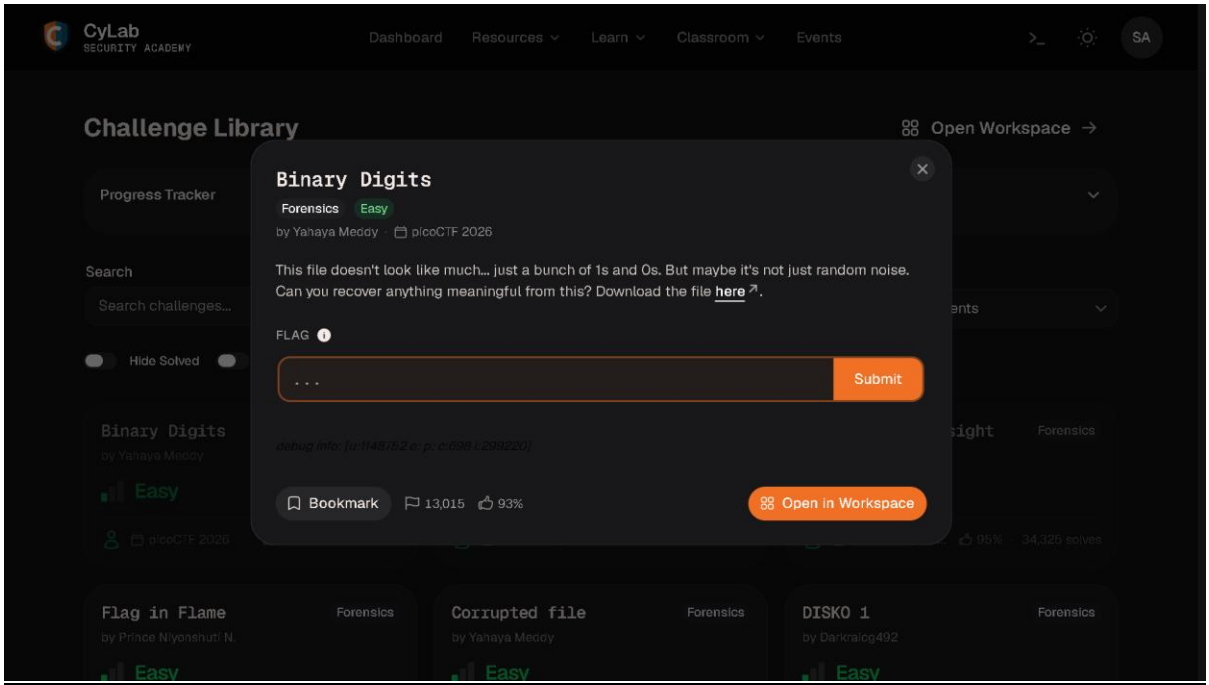
String tersebut berhasil diubah menjadi flag yang kita cari.

Flag: academy{puzzl3d_m3tadata_f0und!_3cc7cea9}

BINARY DIGITS

Menganalisis file berisi deretan angka biner (0 dan 1) untuk menemukan file tersembunyi di dalamnya.

Link: https://learn.cylabacademy.org/library/698



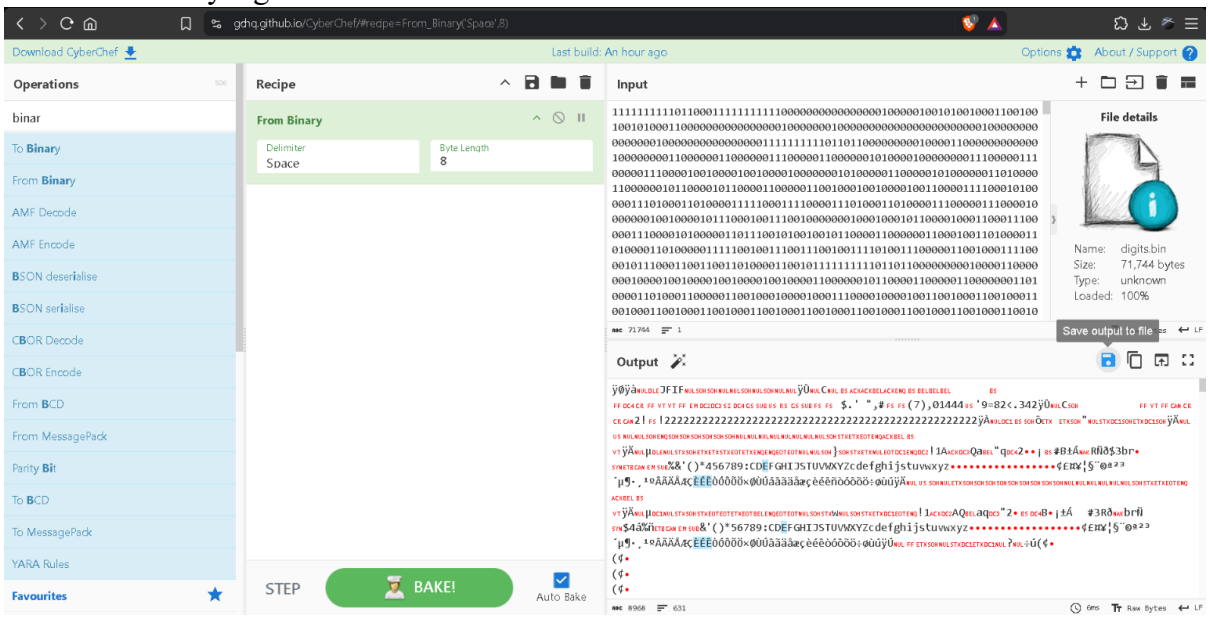

```
┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[2] binarydigits]
└─$ wget https://challenge-files.cylabacademy.net/library/6ba8983da0e17a2e2015a530788849e9c9c0bc3393d62fa3f9a06ce8068567c8/digits.bin
--2026-10-16 18:29:49--  https://challenge-files.cylabacademy.net/library/6ba8983da0e17a2e2015a530788849e9c9c0bc3393d62fa3f9a06ce8068567c8/digit
s.bin
Resolving challenge-files.cylabacademy.net (challenge-files.cylabacademy.net)... 13.35.1.86, 13.35.1.5, 13.35.1.79, ...
Connecting to challenge-files.cylabacademy.net (challenge-files.cylabacademy.net)|13.35.1.86|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 71744 (70K) [application/octet-stream]
Saving to: 'digits.bin'

digits.bin                          100%[=================================================================>]  70.06K   442KB/s    in 0.2s

2026-10-16 18:29:49 (442 KB/s) - 'digits.bin' saved [71744/71744]


┌──(zvk㉿F-35)-[~/Documents/Weekly-CTF-CyberSec-TecArt/week2/forensic/[2] binarydigits]
└─$ file digits.bin
digits.bin: ASCII text, with very long lines (65536), with no line terminators
```

Install dulu file bin yg diberikan dengan wget. File digits.bin yg diintall ternyata berisi 65536 karakter yang seluruhnya merupakan angka 1 dan 0 tanpa line terminator, sesuai dengan namanya “Binary Digits”. File ini kemungkinan besar merupakan representasi biner dari sebuah file lain yang disusun bit demi bit.



Gunakan tools online CyberChef dengan operasi “From Binary”, dan atur delimiter menjadi

space dan byte length menjadi 8 agar setiap 8 digit biner dikonversi kembali menjadi 1 byte data yang utuh. Hasil konversi tersebut menghasilkan data biner mentah yang kemudian saya simpan sebagai file jpg dengan “Save Output to File”.



Setelah file hasil konversi tersebut dibuka, ternyata file itu adalah sebuah gambar JPG yang menampilkan teks flag berwarna merah. Flag pun berhasil didapatkan.

Flag: academy{h1dd3n_1n_th3_b1n4ry_6d751a5b}

Sumber: https://gchq.github.io/CyberChef/